Clase 14 · Malware, ataques físicos y mecanismos de seguridad

Seguridad Informática Básica · Dra. Cintia Quezada Reyes · jueves 15 oct 2026 · Tema 3 · Apuntes y resumen de estudio

PARTE 1 · Apuntes completos

3.1 Ataques basados en malware

Malware (malicious software): código hecho para infiltrarse, alterar o comprometer equipos e infraestructura lógica.

Tipo	Qué hace
Virus y gusanos	Código infeccioso que se replica por la red o por archivos
Troyanos	Parecen un archivo legítimo (ejecutable, imagen, audio) y al abrirse hacen cosas ocultas: abrir puertos, escanear, capturar información
Ransomware	Cifra los datos y pide rescate a cambio de la clave
Spyware	Espía la actividad del usuario en segundo plano
Rootkits	Se ocultan y dan privilegios totales; llegan por pantallas falsas de login o por diccionario/fuerza bruta contra credenciales débiles

Mitigación:

- Antivirus/antimalware: **uno solo**; varios a la vez chocan y consumen recursos hasta alentar o bloquear el equipo.
- **Listas blancas** (lo autorizado) y **listas negras** (salir de una exige justificar formalmente).
- **Control de USB:** bloquearlos por software; TI los habilita solo con permiso.
- La tecnología va más rápido que los reglamentos (los bancos tapaban con etiqueta la cámara de los celulares).

Errores comunes: credenciales por defecto (admin/admin), contraseña igual al usuario o "1234"; creer que más antivirus es más protección.

3.2 Ataques físicos

- **Ataques:** robo de dispositivos, keyloggers físicos, hardware malicioso y **robo hormiga** (cables, adaptadores, ratones que van desapareciendo).
- **Mitigación:** control de acceso físico (bitácoras, torniquetes, guardias, arcos detectores, revisión de mochilas, cámaras), bloqueo automático de sesión por inactividad, cifrado de dispositivos, uniforme o gafete visible.

Error común: cuidar mucho el servidor por software y dejar abierta la puerta del site.

3.3 Medidas según su acción

Acción	Cuándo actúa	Ejemplo
Preventiva	Antes, para evitar el daño	Vacuna contra la influenza
Correctiva	Durante o después, para reducir el impacto	Penicilina cuando ya hay infección
Detectora	Identifica anomalías	Cámaras, monitoreo
Disuasiva	Convence de no hacerlo	"Si tomas, no manejes"

El monitoreo es continuo (diario, semanal, mensual). Error de examen: decir que el ciclo PDCA se aplica "solo cuando hay auditoría"; es mejora continua.

3.4 Mecanismos de seguridad

Definición

Un **mecanismo de seguridad** (herramienta o control) es cualquier aplicación, técnica, recomendación, actividad, consideración, objeto, animal o persona, o combinación de ellos, que se usa para **implementar uno o varios servicios de seguridad**. Responde a "¿cómo lo voy a proteger?".

(Si el servicio es "no tener sed", el mecanismo puede ser un vaso de agua, una limonada o un garrafón.) No hay un mecanismo que dé todos los servicios.

Relación servicio : mecanismo	Ejemplo
1 : 1	Una puerta para el control de acceso
1 : N	Control de acceso con puerta, chapa, biométrico y guardia
N : 1	Un biométrico que da control de acceso y autenticación
N : M	Biométrico multifactor (huella + retina + rostro) para autenticación y control de acceso

Error común: comprar herramientas caras sin analizar qué necesidad cubren.

3.5 Las cuatro clasificaciones de los mecanismos

Criterio	Clases
Servicio que implementa	Confidencialidad, integridad, disponibilidad, no repudio, autenticación, control de acceso
Importancia	**Requeridos** (mínimo indispensable: la puerta y su chapa) y **discrecionales** (complementarios: dos chapas extra)
Cobertura (arquitectura de seguridad OSI)	**Generalizados** (toda la organización: gafete para todos) y **específicos** (una capa, protocolo o grupo: gafete solo de TI)
Acción	Preventivos, correctivos, detectores, disuasivos

3.6 Ejercicio en parejas (SIB-EC04)

Respuestas de las parejas en clase (no es clave oficial; se aceptaba más de una opción justificada):

Mecanismo	Servicio	Importancia	Cobertura	Acción
Firma digital	Autenticación / no repudio	Requerido	Específico	Preventivo
Candado	Control de acceso	Requerido	General	Preventivo
Rejas en ventanas	Control de acceso	Discrecional	Específico	Preventivo / disuasivo
Vacuna	Integridad (salud)	Requerido	Específico	Preventivo
Reglamentos	Integridad / control de acceso	Requerido	General	Disuasivo / preventivo
Contraseñas	Autenticación / control de acceso	Requerido	Específico	Preventivo
Firewalls	Control de acceso / confidencialidad	Requerido	Específico	Preventivo / detector
VPN	Confidencialidad / autenticación	Discrecional o requerido	Específico	Preventivo
Cámaras	—	Discrecional	General	Detector / disuasivo
Penicilina	Integridad (salud)	Requerido	Específico	Correctivo

PARTE 2 · Resumen para estudiar

Versión corta de lo que más probablemente se pregunta. Léela primero y vuelve a la Parte 1 si algo no queda claro.

Malware. Virus/gusanos (se replican), troyanos (disfrazados), ransomware (cifra y pide rescate), spyware (espía), rootkits (privilegios ocultos). Mitigar: **un solo antivirus**, listas blancas/negras, control de USB, nada de credenciales por defecto.

Físicos. Robo, keyloggers, hardware malicioso, robo hormiga → control de acceso, bloqueo de sesión, cifrado, gafete.

> **Mecanismo (examen)**
>
> Lo que implementa uno o varios servicios de seguridad (aplicación, técnica, objeto, persona, animal…); responde "¿cómo lo protejo?". Relaciones 1:1, 1:N, N:1, N:M.

Clasificación	Opciones
Servicio	Confidencialidad, integridad, disponibilidad, no repudio, autenticación, control de acceso
Importancia	Requerido (puerta y chapa) / discrecional (chapas extra)
Cobertura (OSI)	Generalizado (toda la org.) / específico (capa o grupo)
Acción	Preventivo (vacuna) / correctivo (penicilina) / detector / disuasivo